

DOSSIER D'ARCHITECTURE TECHNIQUE

YMMO - INFRA



Matias Bouchenoire | Samuel Bouhnik-Loury | William Pons

Sommaire

Ce document couvre les sections suivantes :

- 1. Schéma d'architecture réseau
- 2. Plan d'adressage IP
- 3. Politique de sécurité
- 4. Plan de gestion des droits d'accès
- 5. Guide de configuration des serveurs
- 6. Plan de sauvegarde et de supervision
- 7. Proposition d'une solution Cloud
- 8. Guide de déploiement
- 9. Liste du matériel et budgétisation

La partie Documentation Technique du DEV est dans le README du GitHub :

<https://github.com/samuelblry/Ymmo.git>

1. Schéma d'architecture réseau

L'architecture du projet YMMO repose sur un modèle Hub-and-Spoke centralisé autour du Siège social (Aix-en-Provence) interconnectant 12 agences distantes via des tunnels VPN sécurisés.

L'infrastructure locale du Siège est segmentée en zones de sécurité (VLANs) via le routeur de tête OPNsense afin de cloisonner les flux et de protéger les données sensibles.



Zones définies

- Zone WAN : accès Internet via OPNsense
- Zone VLAN 20 — DMZ : Serveur Web public (10.0.20.0/24)
- Zone LAN / VLAN 1 — Management & Serveurs : AD, serveur de fichiers (10.0.0.0/24)
- Zone VLAN 30 — USERS : Postes internes siège (10.0.30.0/24)
- Tunnels VPN IPsec IKEv2 : interconnexion des 12 agences

2. Plan d'adressage IP

Le plan d'adressage utilise une structure logique stricte de type '10.Site.Vlan.Poste' permettant d'éviter tout chevauchement de sous-réseaux (overlapping) lors de l'établissement des tunnels VPN.

2.1. Infrastructure du Siège (Aix-en-Provence)

Interface WAN (Transit/Internet) : 192.168.23.142/24 (DHCP environnement de virtualisation — IP fixe en production)

LAN Principal (VLAN 1 — Management & Serveurs) : 10.0.0.0/24

- Passerelle (OPNsense LAN) : 10.0.0.1
- Contrôleur de domaine AD / Serveur de fichiers : 10.0.0.10

VLAN 20 (DMZ — Serveur Web Public) : 10.0.20.0/24

- Passerelle (OPNsense) : 10.0.20.1
- Serveur Web Ubuntu (Nginx) : 10.0.20.10

VLAN 30 (USERS — Postes Internes Siège) : 10.0.30.0/24

- Passerelle (OPNsense) : 10.0.30.1
- Plage DHCP : 10.0.30.50 à 10.0.30.200

2.2. Infrastructure des Agences Distantes

Chaque agence possède un adressage unique basé sur son numéro de site au niveau du deuxième octet :

Site / Entité	Sous-réseau LAN	Passerelle Locale	Usage principal
Agence 01	10.1.0.0/24	10.1.0.1	Postes Commerciaux Agence 1
Agence 02	10.2.0.0/24	10.2.0.1	Postes Commerciaux Agence 2
Agence 03	10.3.0.0/24	10.3.0.1	Postes Commerciaux Agence 3
Agence 04	10.4.0.0/24	10.4.0.1	Postes Commerciaux Agence 4
Agence 05	10.5.0.0/24	10.5.0.1	Postes Commerciaux Agence 5
Agence 06	10.6.0.0/24	10.6.0.1	Postes Commerciaux Agence 6
Agence 07	10.7.0.0/24	10.7.0.1	Postes Commerciaux Agence 7
Agence 08	10.8.0.0/24	10.8.0.1	Postes Commerciaux Agence 8
Agence 09	10.9.0.0/24	10.9.0.1	Postes Commerciaux Agence 9
Agence 10	10.10.0.0/24	10.10.0.1	Postes Commerciaux Agence 10

Site / Entité	Sous-réseau LAN	Passerelle Locale	Usage principal
Agence 11	10.11.0.0/24	10.11.0.1	Postes Commerciaux Agence 11
Agence 12	10.12.0.0/24	10.12.0.1	Postes Commerciaux Agence 12

3. Politique de sécurité

La politique de sécurité d'Ymmo repose sur une approche de défense en profondeur, déclinée en quatre axes stratégiques couvrant le réseau, les identités, l'applicatif et les flux inter-sites.

3.1. Sécurité périmétrique et filtrage réseau

- **Principe du « Default Deny »** : le pare-feu central (OPNsense) applique une politique stricte de blocage par défaut. L'intégralité du trafic entrant et sortant est rejetée à moins qu'une règle explicite ne l'autorise.
- **Exposition minimale (Destination NAT)** : seul le trafic public légitime (requêtes HTTP sur le port TCP 80) est autorisé à franchir l'interface WAN, puis redirigé de manière ciblée vers le serveur reverse proxy interne (Nginx), agissant comme un sas de sécurité.
- **Cloisonnement des zones de confiance** : l'infrastructure est segmentée logiquement pour limiter les surfaces d'attaque :
- **DMZ Web (VLAN 20)** : zone exposée hébergeant le point d'entrée de l'application web.
- **Services privés (VLAN 1 — LAN Management & Serveurs)** : zone critique non routable depuis l'extérieur, abritant l'Active Directory, les services DNS/DHCP et le stockage de données.
- **Postes utilisateurs (VLAN 30)** : réseau isolé dédié aux collaborateurs du siège.

3.2. Gestion des identités et des accès (IAM)

- **Authentification centralisée** : tous les accès au réseau d'entreprise (siège et collaborateurs) sont régis par le contrôleur de domaine Windows Server 2022 via Active Directory (AD DS).
- **Principe de moindre privilège (PoLP)** : les droits d'accès aux ressources partagées (SMB) sont appliqués au plus juste via des permissions NTFS strictes. Un utilisateur ou un groupe n'accède qu'aux répertoires strictement nécessaires à sa fonction.
- **Gouvernance de sécurité des postes** : application de paramètres de sécurité homogènes sur le parc informatique (VLAN 30) via le déploiement de stratégies de groupe (GPO).

3.3. Sécurité applicative et base de données

- **Architecture isolée** : l'API (FastAPI) et le moteur de base de données (PostgreSQL) ne sont jamais exposés directement sur Internet. Nginx gère l'interception et le routage interne des requêtes.
- **Ségrégation des privilèges SQL** : l'application interagit avec la base via un utilisateur de service dédié (ymmo_user), restreint au seul schéma de l'application, l'empêchant d'altérer le système global (droits super-utilisateur révoqués).
- **Sécurité des sessions** : l'authentification web s'appuie sur des jetons chiffrés (JWT, algorithme HS256) pour garantir l'intégrité des échanges, complétée par une double authentification (TOTP) pour les comptes du personnel.

3.4. Continuité et sécurisation des flux inter-sites

- **Chiffrement des communications (VPN IPsec)** : l'ensemble des échanges entre le siège et les 12 agences distantes transite exclusivement au travers de tunnels chiffrés (VPN site à site configurés sur OPNsense), garantissant la confidentialité des données immobilières.

Note de soutenance : ce maillage VPN est défini dans l'architecture cible ; il est hors périmètre de la maquette de démonstration actuelle.

4. Plan de gestion des droits d'accès

La gestion des droits s'appuie sur le cloisonnement des dossiers partagés présents sur le volume réseau commun (S:\). Les droits sont appliqués via des groupes de sécurité Active Directory — aucun utilisateur isolé dans les ACLs NTFS.

4.1. Matrice des droits d'accès réseau

Pôle \ Dossier partagé	Direction	Commercial	Comm. & Marketing	Admin - RH - Juridique	IT et Support
Direction	Lecture / Écriture	Lecture	Lecture	Lecture	Lecture
Commercial	Interdit	Lecture / Écriture	Lecture	Interdit	Interdit
Communication & Marketing	Interdit	Lecture	Lecture / Écriture	Interdit	Interdit
Administratif - RH - Juridique	Interdit	Lecture	Lecture	Lecture / Écriture	Interdit
IT et Support	Interdit	Lecture	Lecture	Interdit	Lecture / Écriture

Groupes de sécurité Active Directory

- GRP_Direction
- GRP_Commercial
- GRP_Communication
- GRP_Admin
- GRP_IT

4.2. Sécurité de visibilité — Access-Based Enumeration (ABE)

Pour éviter la fuite d'informations passive, l'Énumération basée sur l'accès (ABE) est activée sur le partage racine Partage_YMMO. Un utilisateur appartenant au pôle Commercial ne verra même pas l'existence des dossiers Direction ou IT et Support dans son explorateur Windows.

5. Guide de configuration des serveurs

Ce guide synthétise les configurations appliquées sur les nœuds centraux de l'infrastructure Ymmo pour assurer le routage, la sécurité et la disponibilité des services.

5.1. Passerelle et pare-feu central (OPNsense)

- **Interfaces réseau** : WAN (interface publique exposée à Internet), VLAN 1 — LAN (services internes, 10.0.0.0/24), VLAN 20 — DMZ (applications web, 10.0.20.0/24) et VLAN 30 — USERS (postes du siège, 10.0.30.0/24).
- **Routage (NAT)** : mise en place d'une règle de Destination NAT (port forwarding) interceptant le trafic TCP 80 entrant sur l'interface WAN pour le rediriger vers le serveur web Nginx (10.0.20.10).
- **Filtrage (firewalling)** : application d'une règle de blocage stricte en tête de liste sur l'interface DMZ interdisant toute communication initiée depuis la DMZ vers le sous-réseau LAN, empêchant ainsi les rebonds en cas de compromission du service web.

5.2. Serveur web & applicatif (Ubuntu DMZ — 10.0.20.10)

- **Reverse proxy (Nginx)** : configuration d'un bloc serveur écoutant sur le port 80. Les requêtes à la racine / desservent les fichiers statiques (build React) situés dans /var/www/html ; les requêtes ciblant /api sont transmises via proxy_pass au backend local.
- **Backend (FastAPI / Python)** : API isolée dans un environnement virtuel (venv), lancée en mode asynchrone via uvicorn sur le port local 8000. Le service est géré par un démon systemd assurant le redémarrage automatique en cas de crash.
- **Base de données (PostgreSQL)** : hébergée localement pour la maquette, avec une connexion restreinte à l'utilisateur ymmo_user disposant de droits de propriété exclusifs sur le schéma public de la base applicative.

5.3. Serveur d'infrastructure (Windows Server 2022 — 10.0.0.10)

- **Active Directory (AD DS)** : contrôleur de domaine principal gérant les identités du siège et la structure des unités d'organisation (OU) par service.
- **Services réseau (DNS / DHCP)** : résolution de noms interne pour le domaine Ymmo et distribution dynamique des baux IP pour le VLAN 30 (postes clients).
- **Serveur de fichiers (SMB)** : hébergement des dossiers partagés avec application stricte des listes de contrôle d'accès (ACL / NTFS) basées sur les groupes de sécurité AD, garantissant le cloisonnement des données entre départements.

6. Plan de sauvegarde et de supervision

6.1. Stratégie de sauvegarde — Règle du 3-2-1

Pour garantir la résilience des données face aux ransomwares ou pannes matérielles :

- 3 copies des données : 1 production active + 2 sauvegardes
- 2 supports différents : NAS local d'infrastructure (RAID 5) + bande ou disque externe amovible

- 1 copie hors-site : externalisation vers un espace de stockage Cloud immuable (Object Storage)

Fréquence et rétention

- Sauvegarde incrémentielle quotidienne — déclenchée à 2h00
- Sauvegarde complète hebdomadaire — le dimanche
- Rétention 30 jours pour les fichiers généraux
- Rétention 1 an pour la comptabilité et les données RH

6.2. Supervision de l'infrastructure

Mise en place d'une VM de supervision légère (Zabbix ou combo Prometheus/Grafana) chargée de monitorer :

- Statut Up/Down du routeur OPNsense et disponibilité des tunnels VPN des 12 agences (alerting Ping/ICMP)
- État de santé du contrôleur de domaine — espace disque sur S:, utilisation CPU/RAM, réplication AD
- Disponibilité du site web en DMZ (monitoring des requêtes HTTP 200)

Canal d'alerte : envoi automatique de notifications par mail ou webhook Discord/Teams en cas d'incident critique.

7. Proposition d'une solution Cloud

Afin de moderniser l'infrastructure d'YMMO et de réduire les coûts de maintenance des serveurs physiques locaux, une transition vers un modèle de Cloud Hybride est recommandée.

Solution préconisée : Écosystème Microsoft Azure

1. Gestion des identités (Hybride)

Mise en place d'Azure AD Connect sur le serveur local pour synchroniser l'Active Directory ymmo.local existant avec Microsoft Entra ID (anciennement Azure AD) dans le Cloud. Les employés conservent le même compte et les mêmes identifiants.

2. Serveur de fichiers — Migration Cloud

Remplacement du partage réseau physique local par Azure Files. Les dossiers partagés sont hébergés de manière hautement disponible dans le Cloud avec les mêmes droits NTFS qu'en local.

3. Avantages pour YMMO

- Suppression du VPN IPsec lourd pour les agences : les commerciaux accèdent à leurs fichiers via Internet avec MFA, sans passer par le routeur du Siège
- Scalabilité : l'espace de stockage augmente automatiquement sans achat de disques physiques
- Économies : réduction de la facture électrique et de la maintenance matérielle au siège

8. Guide de déploiement

Pour remonter cette infrastructure proprement en laboratoire ou en production, le technicien doit suivre rigoureusement cet ordre :

Étape 1 — Configuration du réseau et des hyperviseurs

Créer les commutateurs virtuels (vSwitches) ou interfaces physiques correspondants au WAN, LAN, VLAN 20 (DMZ) et VLAN 30.

Étape 2 — Déploiement et durcissement d'OPNsense

Installer OPNsense, attribuer les adresses IP statiques aux passerelles de chaque zone. Activer le serveur DHCP sur le VLAN 30. Renseigner les règles de pare-feu initiales.

Étape 3 — Initialisation du contrôleur de domaine (AD)

Installer Windows Server sur le LAN (10.0.0.10), promouvoir la machine en contrôleur de domaine (ymmo.local). Créer l'arborescence des OUs, injecter les utilisateurs de test et créer les partages NTFS. Activer l'ABE.

Structure des Unités d'Organisation (OU)

OU racine : YMMO

Siege_Aix > Ordinateurs

Siege_Aix > Utilisateurs

Agences > Agence_01 à Agence_12 (12 sous-OUs distinctes)

Étape 4 — Déploiement de la GPO de mappage

Créer et lier la GPO GPO_Mappage_Lecteur_S sur l'OU racine YMMO :

- Action : Mettre à jour
- Emplacement : \\ymmo.local\Partage_YMMO
- Lettre : S:
- Reconnecter : activé

Étape 5 — Intégration du serveur web et validation DMZ

Déployer la VM Ubuntu dans la DMZ (10.0.20.10). Installer Nginx. Vérifier depuis le client externe que le site répond, et valider que le serveur Web ne peut pas joindre l'AD (10.0.0.10).

Étape 6 — Recette des PC clients

Joindre une machine cliente au domaine ymmo.local. Se connecter avec les comptes de test (ex : jcommercial). Vérifier que le lecteur S: monte automatiquement et que les restrictions de dossiers fonctionnent correctement.

9. Liste du matériel et budgétisation

L'architecture cible Ymmo s'appuie sur une infrastructure physique centralisée au siège (Hub) et des équipements réseau légers déployés dans les 12 agences (Spokes). Ce budget prévisionnel (CAPEX) couvre l'acquisition du matériel et des licences de base pour un déploiement réel.

9.1. Inventaire matériel (cible de production)

Catégorie	Description de l'équipement	Qté	Affectation
Sécurité (Hub)	Appliance firewall matérielle (ex. Netgate 6100 / FortiGate 60F) supportant l'inspection NAT/IPS/IDS et les 12 tunnels VPN IPsec.	1	Siège
Routage (Spokes)	Routeurs/pare-feu compacts avec support IPsec matériel (ex. MikroTik hEX ou Netgate 2100).	12	Agences
Serveurs	Serveurs rack 1U/2U (ex. Dell PowerEdge R650) pour cluster d'hypervision (VMware/Proxmox) hébergeant les VLAN 1 et 20.	2	Siège
Commutation	Switchs manageables L2/L3 (24/48 ports PoE) pour distribuer les VLAN.	3	Siège
Postes clients	Ordinateurs professionnels (fixes/portables) pour les collaborateurs.	~90	Siège & Agences
Périphériques	Serveur/copieur d'impression réseau professionnel.	1	Siège

9.2. Estimation budgétaire initiale

Les tarifs ci-dessous sont des estimations moyennes (hors taxes) basées sur les prix du marché B2B pour du matériel professionnel garanti sur site.

Pôle de dépense	Détail prévisionnel	Budget estimé (HT)
Infrastructure cœur (serveurs)	2× serveurs physiques (hyperviseurs) avec stockage SSD RAID et RAM ECC	12 000 €
Réseau et sécurité (siège)	1× appliance firewall haute disponibilité + 3× switchs L3	4 500 €
Réseau périphérique (agences)	12× routeurs VPN (env. 350 € / unité)	4 200 €
Parc informatique utilisateurs	~90× postes de travail professionnels (env. 800 € / unité)	72 000 €
Périphériques & impressions	1× imprimante/copieur multifonction	1 500 €
Licences logicielles	Windows Server 2022 (Standard), CALs AD utilisateurs, souscription Azure de base	4 800 €
TOTAL ESTIMÉ DE L'INVESTISSEMENT (CAPEX)		99 000 €

Note technique : les coûts récurrents (OPEX) — abonnements fibre (siège + 12 agences), maintenance infogérée et consommations Azure Cloud — ne sont pas inclus dans cette enveloppe initiale de déploiement.